

Data Breach Response Plan

Department:	Security	Document Owner:	Chief Information Security Officer
Version:	2.0	Effective Date:	2024-01-20
Document ID:	SOP-SEC-001	Review Cycle:	Annual

1. Purpose

Define the organization's response to confirmed or suspected data breaches to contain damage, meet legal obligations, and restore security.

2. Scope

All incidents involving unauthorized access, disclosure, or exfiltration of personal or confidential company data.

3. Procedure

Step 1: Detection & Initial Assessment

Security team or employee identifies potential breach. Report immediately to security@company.com and CISO. Do NOT attempt to fix or delete evidence. Preserve logs and affected systems. Initial assessment determines if breach is confirmed or suspected.

Step 2: Containment

Isolate affected systems from network. Revoke compromised credentials. Apply emergency patches or firewall rules. Preserve forensic evidence before containment actions where possible. Document all actions with timestamps.

Step 3: Legal & Compliance Notification

Notify Legal within 1 hour of confirmed breach. Legal assesses regulatory notification requirements (GDPR 72 hours, state laws vary). Do not communicate externally without Legal approval. Engage cyber insurance carrier.

Step 4: Forensic Investigation

Engage internal forensics team or retain external IR firm. Determine: entry point, data accessed/exfiltrated, duration of exposure, affected individuals. Produce written forensic report.

Step 5: Notification to Affected Parties

Draft notification per Legal guidance. Notify affected individuals within regulatory timeframes. Offer credit monitoring if PII involved. Maintain log of all notifications sent.

Step 6: Eradication & Recovery

Remove malware, backdoors, and compromised accounts. Restore systems from clean backups. Implement enhanced monitoring. Phased return to production with security validation.

Step 7: Post-Breach Review

Conduct lessons-learned within 30 days. Update security controls and policies. Present findings to Board if material breach. Track remediation items to closure.

4. References & Related Documents

- Information Security Policy v4.0
- GDPR Compliance Guide
- Incident Response Retainer Agreement

5. Revision History

Version	Date	Description of Change
2.0	2024-01-20	Aligned with new cyber insurance requirements
1.5	2023-03-01	Added GDPR timeline details
1.0	2022-01-01	Initial release